# SOFTWARE ENGINEERING

## Lab 5: Static Code Analysis

Wildlife Sanctuary Sightings Log

https://github.com/cosmocode-source/SE-Labs-PES1UG24CS079/tree/main/Lab-5

| Prepared by | Arin Singh |
|---|---|
| SRN | PES1UG24CS079 |
| Course | UE24CS341A : Software Engineering |

### 1. Introduction

Static code analysis examines source code without executing the target program. This lab uses three tools to improve the quality, security and style of wildlife_sightings.py.

| Tool | Role |
|---|---|
| Pylint | Checks programming practices, naming and documentation; provides a quality score. |
| Bandit | Identifies common security risks and reports severity and confidence. |
| Flake8 | Checks style, line length, whitespace and related code issues. |

| Tool | Before | After (supplied reports) |
|---|---|---|
| Pylint | 3.46/10 | 9.66/10; final newline warning |
| Bandit | 3 findings | No issues identified |
| Flake8 | 6 findings | 1 finding: W292 |

### Original program output

```
(venv) C:\Users\arinv\Downloads\Software Engineering\SE Labs\SE-Labs-PES1UG24CS079\Lab-5\L5_21_wildlife_sightings>python ".\wildlife_sightings.py"
5455c3 25 Leopard

(venv) C:\Users\arinv\Downloads\Software Engineering\SE Labs\SE-Labs-PES1UG24CS079\Lab-5\L5_21_wildlife_sightings>
```

The supplied after reports retain a missing-final-newline warning. Pylint exceeds 9.5/10 and Bandit is clear; Flake8 still requires that final formatting fix.

# 2. Issues and fixes

Line numbers refer to the original file, except the remaining newline issue. Related findings are grouped to avoid repetition.

| Issue / tool code | Type | Line(s) | Description and fix |
|---|---|---|---|
| MD5 — B324 | Security: High | 15 | Weak hash flagged by Bandit. Replace MD5 with SHA-256. A retained six-character ID is not collision-resistant or an authentication token. |
| SQL formatting — B608 / C0209 | Security: Medium | 9 | Interpolated input can alter SQL. Replace .format() with SQLite ? placeholders and pass values separately, not with an f-string. |
| Assertion — B101 | Reliability: Low | 36 | Assertions may be removed under optimisation. Replace with an explicit condition raising ValueError. |
| Mutable default — W0102 | Bug | 8–10 | A default dictionary is shared between calls. Use extras=None and initialise a dictionary inside the function. |
| Documentation — C0114 / C0116 | Docs | 1; 8, 14, 18, 26, 32 | Missing module and function descriptions. Add concise docstrings. |
| Names and scope — C0103 / W0621 | Code quality | 8, 14, 18, 26 | Use snake_case function names and update calls. Rename conn parameters to connection to avoid shadowing the global name. |
| Unnecessary else — R1705 | Code quality | 20–23 | The if branch already returns. Remove else and return the result directly afterwards. |
| Long lines — C0301 / E501 | Formatting | 5, 9, 19, 27 | Wrap SQL strings and method calls across lines, keeping each within 79 characters. |
| Variable and spacing — E741 / E225 | Style | 28–29 | Replace l=min(...) with rarest_row = min(...) and update its use. |
| Final newline — C0304 / W292 | Remaining | 63 (after) | Add a newline after the final main() call and rerun the tools. This warning remains in both supplied after reports. |

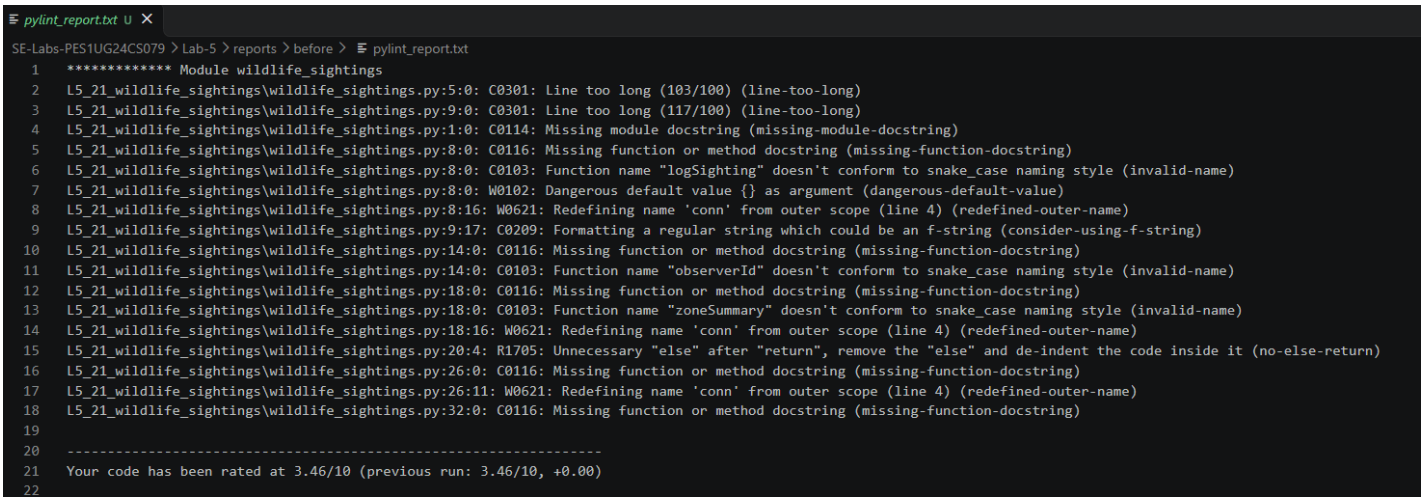
Why these changes matter

Parameterised queries keep SQL instructions separate from data, so a species name containing a quote is handled as a value rather than part of the query. Using None for the dictionary default also ensures that independent calls do not accidentally share totals.

Docstrings, descriptive names and simpler return logic improve readability and maintenance. The SHA-256 change removes the MD5 finding, but shortening any hash to six characters still permits collisions.

# 3. Screenshot and reflection

Pylint before fixes: supplied VS Code screenshot.



pylint_report.txt U

SE-Labs-PES1UG24CS079 > Lab-5 > reports > before > pylint_report.txt

```
1   ************* Module wildlife_sightings
2   L5_21_wildlife_sightings\wildlife_sightings.py:5:0: C0301: Line too long (103/100) (line-too-long)
3   L5_21_wildlife_sightings\wildlife_sightings.py:9:0: C0301: Line too long (117/100) (line-too-long)
4   L5_21_wildlife_sightings\wildlife_sightings.py:1:0: C0114: Missing module docstring (missing-module-docstring)
5   L5_21_wildlife_sightings\wildlife_sightings.py:8:0: C0116: Missing function or method docstring (missing-function-docstring)
6   L5_21_wildlife_sightings\wildlife_sightings.py:8:0: C0103: Function name "logSighting" doesn't conform to snake_case naming style (invalid-name)
7   L5_21_wildlife_sightings\wildlife_sightings.py:8:0: W0102: Dangerous default value {} as argument (dangerous-default-value)
8   L5_21_wildlife_sightings\wildlife_sightings.py:8:16: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
9   L5_21_wildlife_sightings\wildlife_sightings.py:9:17: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
10  L5_21_wildlife_sightings\wildlife_sightings.py:14:0: C0116: Missing function or method docstring (missing-function-docstring)
11  L5_21_wildlife_sightings\wildlife_sightings.py:14:0: C0103: Function name "observerId" doesn't conform to snake_case naming style (invalid-name)
12  L5_21_wildlife_sightings\wildlife_sightings.py:18:0: C0116: Missing function or method docstring (missing-function-docstring)
13  L5_21_wildlife_sightings\wildlife_sightings.py:18:0: C0103: Function name "zoneSummary" doesn't conform to snake_case naming style (invalid-name)
14  L5_21_wildlife_sightings\wildlife_sightings.py:18:16: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
15  L5_21_wildlife_sightings\wildlife_sightings.py:20:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
16  L5_21_wildlife_sightings\wildlife_sightings.py:26:0: C0116: Missing function or method docstring (missing-function-docstring)
17  L5_21_wildlife_sightings\wildlife_sightings.py:26:11: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
18  L5_21_wildlife_sightings\wildlife_sightings.py:32:0: C0116: Missing function or method docstring (missing-function-docstring)
19
20  --------------------------------------------------------------------
21  Your code has been rated at 3.46/10 (previous run: 3.46/10, +0.00)
22
```

Reflection

The manual references reflection questions but does not list them. These are concise topic-based responses, not the manual's exact questions.

Purpose of the tools: Pylint found quality and documentation issues; Bandit found security risks; Flake8 found style problems. Their different scopes made the review more complete.

Most important fixes: Parameterised SQL separates data from instructions. Replacing the mutable default prevents unintended shared state. Explicit validation remains active when assertions are disabled.

Results and remaining work: Pylint increased to 9.66/10 and Bandit reports no findings. The original Flake8 findings are absent, but a missing final newline still needs correction and verification.

Limitations: Static analysis does not prove correct behaviour or complete security. Runtime checks and tests remain necessary; a short hash-based ID can still collide.

How to interpret the results

The before reports establish the original problems. The after reports show that the original warnings are no longer present, while also exposing one remaining formatting issue. This comparison is stronger evidence than a score alone.

Pylint's 9.66/10 meets the required score above 9.5. Bandit's zero findings means its enabled checks found no flagged patterns, not that security is guaranteed. Flake8's W292 means the file must end with a newline; rerunning the tools after adding it is necessary before claiming a clean result.

# 4. Before-and-after reports

Terminal-style reconstructions of the uploaded text; not new execution screenshots.

### Pylint — before changes

```
(venv) C:\Users\arinv\Downloads\Software Engineering\SE
Labs\SE-Labs-PES1UG24CS079\Lab-5\L5_21_wildlife_sightings>type "..\reports\before
changes\pylint_report.txt"

************* Module wildlife_sightings
L5_21_wildlife_sightings\wildlife_sightings.py:5:0: C0301: Line too long (103/100)
(line-too-long)
L5_21_wildlife_sightings\wildlife_sightings.py:9:0: C0301: Line too long (117/100)
(line-too-long)
L5_21_wildlife_sightings\wildlife_sightings.py:1:0: C0114: Missing module docstring
(missing-module-docstring)
L5_21_wildlife_sightings\wildlife_sightings.py:8:0: C0116: Missing function or method
docstring (missing-function-docstring)
L5_21_wildlife_sightings\wildlife_sightings.py:8:0: C0103: Function name "logSighting" doesn't
 conform to snake_case naming style (invalid-name)
L5_21_wildlife_sightings\wildlife_sightings.py:8:0: W0102: Dangerous default value {} as
argument (dangerous-default-value)
L5_21_wildlife_sightings\wildlife_sightings.py:8:16: W0621: Redefining name 'conn' from outer
scope (line 4) (redefined-outer-name)
L5_21_wildlife_sightings\wildlife_sightings.py:9:17: C0209: Formatting a regular string which
could be an f-string (consider-using-f-string)
L5_21_wildlife_sightings\wildlife_sightings.py:14:0: C0116: Missing function or method
docstring (missing-function-docstring)
L5_21_wildlife_sightings\wildlife_sightings.py:14:0: C0103: Function name "observerId" doesn't
 conform to snake_case naming style (invalid-name)
L5_21_wildlife_sightings\wildlife_sightings.py:18:0: C0116: Missing function or method
docstring (missing-function-docstring)
L5_21_wildlife_sightings\wildlife_sightings.py:18:0: C0103: Function name "zoneSummary"
doesn't conform to snake_case naming style (invalid-name)
L5_21_wildlife_sightings\wildlife_sightings.py:18:16: W0621: Redefining name 'conn' from outer
 scope (line 4) (redefined-outer-name)
L5_21_wildlife_sightings\wildlife_sightings.py:20:4: R1705: Unnecessary "else" after "return",
 remove the "else" and de-indent the code inside it (no-else-return)
L5_21_wildlife_sightings\wildlife_sightings.py:26:0: C0116: Missing function or method
docstring (missing-function-docstring)
L5_21_wildlife_sightings\wildlife_sightings.py:26:11: W0621: Redefining name 'conn' from outer
 scope (line 4) (redefined-outer-name)
L5_21_wildlife_sightings\wildlife_sightings.py:32:0: C0116: Missing function or method
docstring (missing-function-docstring)

-------------------------------------------------------------------
Your code has been rated at 3.46/10 (previous run: 3.46/10, +0.00)
```

# 4. Before-and-after reports (cont.)

### Bandit — before changes

```
(venv) C:\Users\arinv\Downloads\Software Engineering\SE
Labs\SE-Labs-PES1UG24CS079\Lab-5\L5_21_wildlife_sightings>type "..\reports\before
changes\bandit_report.txt"

[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.10
Run started:2026-10-28 07:10:02.361853+00:00

Test results:
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based
query construction.
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info:
https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: .\.\L5_21_wildlife_sightings\wildlife_sightings.py:9:17
8   def logSighting(conn, species, zone, count, extras={}):
9       conn.execute("INSERT INTO sightings (species, zone, count) VALUES ('{}', '{}',
{})".format(species, zone, count))
10      extras[species] = extras.get(species, 0) + count

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\.\L5_21_wildlife_sightings\wildlife_sightings.py:15:11
14  def observerId(observer):
15      return hashlib.md5(observer.encode()).hexdigest()[:6]
16

--------------------------------------------------
>> Issue: [B101:assert_used] Use of assert detected. The enclosed code will be removed when
compiling to optimised byte code.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b101_assert_used.html
   Location: .\.\L5_21_wildlife_sightings\wildlife_sightings.py:36:4
35      logSighting(conn, "Hornbill", "East", 3, totals)
36      assert len(totals) == 3
37      print(observerId("Arun"), zoneSummary(conn, "North"), rarest(conn))

--------------------------------------------------

Code scanned:
    Total lines of code: 27
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
```

# 4. Before-and-after reports (cont.)

### Bandit — before changes (continued)

```
(venv) C:\Users\arinv\Downloads\Software Engineering\SE
Labs\SE-Labs-PES1UG24CS079\Lab-5\L5_21_wildlife_sightings>type "..\reports\before
changes\bandit_report.txt"

        Low: 1
        Medium: 1
        High: 1
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 1
        High: 2
Files skipped (0):
```

### Flake8 — before changes

```
(venv) C:\Users\arinv\Downloads\Software Engineering\SE
Labs\SE-Labs-PES1UG24CS079\Lab-5\L5_21_wildlife_sightings>type "..\reports\before
changes\flake8_report.txt"

.\L5_21_wildlife_sightings\wildlife_sightings.py:5:80: E501 line too long (103 > 79
characters)
.\L5_21_wildlife_sightings\wildlife_sightings.py:9:80: E501 line too long (117 > 79
characters)
.\L5_21_wildlife_sightings\wildlife_sightings.py:19:80: E501 line too long (93 > 79
characters)
.\L5_21_wildlife_sightings\wildlife_sightings.py:27:80: E501 line too long (96 > 79
characters)
.\L5_21_wildlife_sightings\wildlife_sightings.py:28:5: E741 ambiguous variable name 'l'
.\L5_21_wildlife_sightings\wildlife_sightings.py:28:6: E225 missing whitespace around operator
```

### Pylint — after changes

```
(venv) C:\Users\arinv\Downloads\Software Engineering\SE
Labs\SE-Labs-PES1UG24CS079\Lab-5\L5_21_wildlife_sightings>type "..\reports\after
changes\pylint_report.txt"

************* Module wildlife_sightings
L5_21_wildlife_sightings\wildlife_sightings.py:63:0: C0304: Final newline missing
(missing-final-newline)

-------------------------------------------------------------------
Your code has been rated at 9.66/10 (previous run: 3.46/10, +6.19)
```

# 4. Before-and-after reports (cont.)

### Bandit — after changes

```
(venv) C:\Users\arinv\Downloads\Software Engineering\SE
Labs\SE-Labs-PES1UG24CS079\Lab-5\L5_21_wildlife_sightings>type "..\reports\after
changes\bandit_report.txt"

[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.10
Run started:2026-10-28 07:25:06.249383+00:00

Test results:
    No issues identified.

Code scanned:
    Total lines of code: 31
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
Files skipped (0):
```

### Flake8 — after changes

```
(venv) C:\Users\arinv\Downloads\Software Engineering\SE
Labs\SE-Labs-PES1UG24CS079\Lab-5\L5_21_wildlife_sightings>type "..\reports\after
changes\flake8_report.txt"

.\L5_21_wildlife_sightings\wildlife_sightings.py:63:7: W292 no newline at end of file
```